Mestrado em Engenharia Biomédica

2024/2025

Unidade Curricular: Sistemas Distribuídos e Segurança Informática

Event Logging

Docentes:

Jorge Pinto Leite

Pedro Rodrigues

Autores:

Ana Sofia Pinto[1], Camila Hayashida[2], Lícia Almeida[3], Mariana Pinto[4]

[1]1211040@isep.ipp.pt

[2]1211843@isep.ipp.pt

[3]1211459@isep.ipp.pt

[4]1210999@isep.ipp.pt

Índice

1. Introdução 1
1.1. Segurança Informática – Contextualização 1
1.2. Análise de Riscos e Aplicação de Práticas de Segurança 2
1.3. Objetivos do Trabalho 3
2. Análise de Riscos em *Event Logging* 4
2.1. Definição e Função do *Event Logging* 4
2.2 Tipos de Eventos 4
2.3 Riscos Associados ao *Event Logging* 6
2.4 *Event Logging* em Sistemas Operativos 7
3. Análise de Riscos de Segurança 9
3.1 Abordagens Utilizadas 9
3.2 Vulnerabilidades 11
4. Práticas de Segurança Aplicáveis ao Event Logging 12
4.1 Diretrizes Essenciais para Configuração de Registos de Eventos 12
4.2 Estratégias para Retenção de Registos 13
5. Conclusão 14

1. Introdução

O presente relatório está dividido em cinco capítulos, sendo o primeiro uma introdução, onde é a apresentada uma contextualização do trabalho e o seu objetivo, bem como, em detalhe, a análise de risco e a aplicação de práticas de segurança. Nos segundo e terceiro capítulos, são explorados os temas "Análise de Riscos em Event Logging" e "Análise de Riscos de Segurança", respetivamente. Finalmente, abordam-se as práticas de segurança aplicáveis ao event logging, no quarto capítulo, que contém as diretrizes essenciais para configuração de registos de eventos, estratégias para retenção de registos, e, ainda, métodos para monitorização e identificação de anomalias. Por fim, é feita uma conclusão do relatório realizado.

1.1. Segurança Informática – Contextualização

A criação da Internet acarretou benefícios, mas também trouxe desvantagens, como a criação de novos crimes ou a prática dos mesmos, através do uso informático. A criminalidade gerada torna-se frequentemente atribuída à falta de medidas de segurança adequadas, podendo ser minimizada por meio da conscientização da população sobre a adoção das práticas necessárias. Perante o estado de risco de uma emergente ameaça informática é imperativo a delineação de medidas e estratégias de segurança [1].

Atualmente, ainda existe alguma ambiguidade quando nos referimos aos conceitos de segurança da informação e de segurança informática. Estes dois termos apesar de serem complementares entre si, têm objetivos diferentes [1]. A segurança informática define-se como a proteção conferida a um sistema de informação, a fim de atingir os objetivos aplicáveis à preservação da integridade, disponibilidade e confidencialidade dos recursos do mesmo [2]. A segurança da informação, por sua vez pode ser definida como a preservação desses mesmos valores, englobando todos os corporativos que precisam de ser protegidos, incluindo aqueles em suportes de dados analógicos, como o papel [3].

Um aspeto central e crítico do problema de segurança informática é a questão do *software*, pelo que defeitos neste possuem implicações que comprometem a preservação do sistema. Uma vulnerabilidade de *software* trata-se, por sua vez, de uma fraqueza no sistema, classificadas em duas categorias principais, remetendo a falhas de

implementação, como *buffer overflows,* e falhas de *design*, como tratamento inconsistente de erros no código. Desta forma, torna-se frequente intrusos mal-intencionados invadirem sistemas explorando esses defeitos. A segurança de *software* ocupa um papel fundamental no ciclo de vida do seu desenvolvimento, integrando-se em todas as fases, minimizando vulnerabilidades e promovendo a resiliência contra ameaças cibernéticas em cada etapa do processo [4]. A figura 1, posteriormente apresentada, retrata esse procedimento.

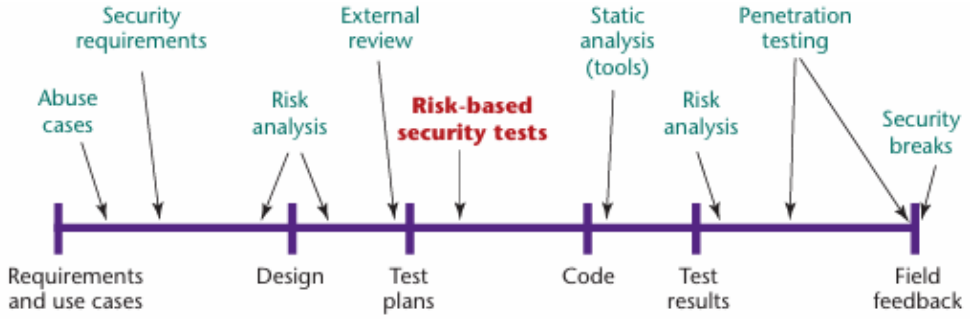

Figura 1. Posicionamento estratégico da segurança de software no ciclo de vida do desenvolvimento do mesmo [4].

Os controlos de segurança da informação, como relatórios de incidentes e ferramentas de visualização, são recomendados para reduzir a anonimidade. Trilhos de auditoria e *event logging* propõe-se que sejam completamente à prova de adulteração, de forma a evitar manipulações por utilizadores maliciosos. Deste modo, a prática de *event logging* é fundamental para a segurança da informação, pois permite a monitorização, auditoria e análise de incidentes em sistemas informáticos e redes [5].

1.2. Análise de Riscos e Aplicação de Práticas de Segurança

Os riscos de cibersegurança que afetam os sistemas de controlo industrial aumentaram significativamente nos últimos anos, principalmente devido à crescente atividade de cibercriminosos. Os atacantes tornaram-se mais sofisticados e a sua deteção precisa e atempada tornou-se um verdadeiro desafio. A análise de risco é, portanto, um processo fundamental para identificar, avaliar e mitigar ameaças e vulnerabilidades nos sistemas de informação. Através da análise de riscos, é possível

prever potenciais falhas e ataques, ajudando na proteção dos sistemas críticos e na tomada de decisões rápidas e informadas [6].

Embora muitas das soluções de monitorização forneçam interfaces gráficas amigáveis, as capacidades de visualização e reação a eventos são frequentemente limitadas, especialmente ao lidar com grandes volumes de dados registados. Por esse motivo, é importante desenvolver extensões de visualização e análise, que forneçam aos utilizadores uma visão de alto nível sobre a situação de segurança, permitindo uma tomada de decisões mais eficiente [6].

Neste contexto, os *logs* de eventos desempenham um papel imprescindível. Os dados de *log* contêm frequentemente grandes quantidades de atividades do sistema que, quando analisadas corretamente, podem ser usadas para ajustar os sistemas e melhorar a segurança. O registo de atividades (*event logging*) também é essencial para implementar sistemas de deteção de intrusões (IDS), que monitorizam as redes ou *hosts* à procura de atividades maliciosas ou violações de políticas de segurança. Os IDS registam dados relacionados a essas atividades e verificam-nos em tempo real, para atividades suspeitas utilizando padrões pré-definidos [7].

Desta forma, a análise de risco aliada à aplicação de práticas de segurança eficazes garante uma postura proativa na defesa contra ameaças, além de contribuir para a conformidade regulatória e para a integridade dos sistemas de informação.

1.3. Objetivos do Trabalho

Este trabalho tem como principal objetivo explorar o papel do *event logging* e a sua importância na segurança computacional. Para além disso, pretende-se, através do desenvolvimento do presente relatório e da pesquisa bibliográfica, adquirir e aprofundar conhecimentos de temáticas inerentes à Unidade Curricular de Sistemas Distribuídos e Segurança Informática. Assim, este trabalho aborda essencialmente: a identificação de riscos de segurança associados ao *event logging* e ao seu uso inadequado ou negligente; a análise desses riscos, incluindo a identificação de potenciais vulnerabilidades e as suas causas subjacentes, e, finalmente, a apresentação de propostas de práticas de segurança e medidas de mitigação destinadas a minimizar os riscos relacionados ao *event logging*.

2. Análise de Riscos em *Event Logging*

Neste capítulo são analisados os riscos em *event logging*, começando pela definição do mesmo, seguida de uma breve explicação sobre os tipos de eventos existentes, e, terminando com os riscos associados a este tema.

2.1. Definição e Função do *Event Logging*

Event logging é o registo de dados numéricos e textuais relativos ao comportamento de um sistema informático, contendo informações detalhadas sobre ações realizadas, erros e outras atividades relevantes [8]. Os *event logs* registam os eventos da interface do utilizador, o respetivo tempo e ordem de ocorrência, bem como os objetos da interface manipulados em cada ação, fornecendo, assim, um registo detalhado das atividades realizadas [9]. Os dados recolhidos são geralmente armazenados num conjunto de ficheiros, também designado, como referido anteriormente, por *event logging* [8].

Nas últimas décadas, tanto organizações académicas como industriais reconheceram o valor do registo de *logs* para diversos fins, como a contabilidade, a medição do desempenho de sistemas e a resolução de problemas. Representam um dos meios mais fiáveis para obter *insights* sobre o comportamento de sistemas informáticos [8]. Mais importante ainda, os registos são utilizados numa ampla variedade de finalidades, como *debugging*, gestão de configurações, controlo de acessos, monitorização e *profiling*. Em muitos casos, tornam-se essenciais para analisar o comportamento de falhas do sistema, oferecendo uma perspetiva crítica em situações de alta carga de trabalho. Por exemplo, estes têm sido utilizados com sucesso para investigar o comportamento de falhas em sistemas operativos, supercomputadores e aplicações distribuídas de grande escala [10].

2.2 Tipos de Eventos

Os ficheiros de *log* contribuem para reforçar as medidas de segurança existentes, fornecendo informações sobre comportamentos suspeitos dos utilizadores e os sistemas que causam intrusões. No entanto, os IDS que utilizam ficheiros de *log* continuam a enfrentar dificuldades em detetar ataques desconhecidos. A correlação de *logs* e outros

conceitos de mineração de dados, como agrupamento (*clustering*) e regras de associação, podem ser utilizados para mitigar este problema [11]. Um arquivo de *log* pode ser caracterizado pela sua localização [12].

2.2.1 Ficheiros de *log* do servidor

Um ficheiro de *log web* é um ficheiro de texto que regista as atividades realizadas no servidor *web*, recolhendo e armazenando informações como: data, hora, endereço IP do cliente, referenciador, agente do utilizador, entre outros. Assim, estes ficheiros são úteis para analisar o desempenho do servidor e otimizar a experiência de navegação [11]. Esses *logs* contêm informações pessoais e sensíveis e, portanto, os proprietários dos servidores geralmente mantêm-nos fechados [12].

2.2.2 Ficheiros de *log* do cliente

Os ficheiros de *log* do lado do cliente contêm dados recolhidos pelo mesmo durante a execução de um *script* na sua máquina. Este é enviado pelo servidor juntamente com o documento *web* [11]. Os participantes testam remotamente um site baixando *software* que regista *logs* da *Web* ou modificando o código-fonte de um navegador existente [12].

2.2.3 Ficheiros de *log* do lado do *proxy*

O servidor *proxy* está presente entre a máquina cliente e o servidor, reduzindo a carga do servidor *web* ao processar os pedidos das páginas que já estão disponíveis [11]. Ou seja, recebe as solicitações HTTP dos utilizadores e transfere-as para um servidor *web*, retornando os resultados enviados por este servidor para o cliente [12]. Além disso, o servidor proxy mantém um ficheiro de *log* que regista todas as solicitações feitas pelos utilizadores, como o endereço IP do utilizador que fez o pedido, a URL da página solicitada, a data e hora do pedido, se a página foi entregue a partir do cache ou se foi necessário solicitar ao servidor web, e o *status* da requisição [13].

2.2.4 Ficheiros de *log* do lado da *firewall*

Os ficheiros de *log* da *firewall* registam apenas os eventos que são negados pelo sistema, sendo a análise desses ficheiros vital para a deteção de intrusões [11].

2.2.5 Ficheiros de *log* do lado da rede

Os ficheiros de log do lado da rede podem ser obtidos a partir de componentes da rede, como *firewalls* de rede, *routers* e filtros de pacotes para análise. Estes ficheiros têm uma vantagem sobre outros tipos de registos, pois não levantam questões legais relacionadas com a violação da privacidade dos dados do utilizador [11].

2.2.6 Ficheiros de *log* do sistema

Os ficheiros de *log* do sistema gerem as informações geradas pelo *kernel* e pelas ferramentas do sistema, fornecendo detalhes sobre as atividades do sistema operativo. Além disso, libertam o programador da tarefa de escrever *logs* manualmente [11]. Um exemplo trata-se do registo pelos componentes do sistema *Windows*, pré-definidos pelo próprio sistema operativo, como, por exemplo, a falha de um *driver* ao carregar durante o arranque [14].

Por outro lado, existem diversos outros tipos de *logs* como o *log* de aplicação que, por sua vez, regista eventos específicos de programas ou aplicações informáticas, como uma atualização de base de dados, e *log* de segurança, que regista eventos relacionados com tentativas de *login*, utilização de recursos de *hardware*, entre outros [14].

2.3 Riscos Associados ao *Event Logging*

O *event login* ao ser uma prática essencial para a monitorização e segurança de sistemas informáticos, apresenta riscos que se não forem mitigados, podem comprometer a integridade, confidencialidade e disponibilidade de sistemas de dados.

Desta forma, um dos principais riscos associados ao *event login* é a exposição de dados sensíveis. Os *logs* podem conter informações como credenciais, *tokens* de autenticação, identificadores pessoais e detalhes do sistema (configurações de rede e versões de *software*). Caso esses *logs* não sejam armazenados ou transmitidos de maneira segura, podem ser explorados por atacantes que utilizem as informações para comprometer sistemas adicionais. Outro risco significativo é o armazenamento e transmissão não seguros, devido à falta de criptografia durante essas etapas, que aumenta a vulnerabilidade à intercetação ou modificação de dados, facilitando ataques como o *man-in-the-middle*. Adicionalmente, um volume excessivo de dados gerados, especialmente em sistemas distribuídos, pode levar ao problema conhecido como *log*

overload, onde informações críticas se perdem em meio a uma quantidade excessiva de dados irrelevantes, dificultando a análise eficiente e atrasando a identificação de incidentes. A manipulação ou alteração de *logs* por atacantes também é um problema comum [15]. Quando os *logs* não são devidamente protegidos contra alterações, estes podem ser adulterados ou apagados, comprometendo investigações futuras. Além disso, a falta de controlo de acesso adequado aos *logs* representa outro desafio. Sem restrições rigorosas, utilizadores não autorizados podem visualizar, modificar ou excluir informações, aumentando os riscos de violação. Para além disso, configurações inadequadas dos sistemas de *logging* também podem gerar problemas, na medida que registos insuficientes criam lacunas importantes na visibilidade do comportamento do sistema, enquanto a captura excessiva pode incluir informações irrelevantes, expondo dados sensíveis e consumindo recursos desnecessários. A falta de padronização nos formatos e conteúdos dos *logs* também dificulta a análise, especialmente em arquiteturas distribuídas [15], [16]. *Logs* gerados por diferentes dispositivos ou aplicações sem consistência tornam a correlação entre eventos uma tarefa complexa. Por fim, os *logs* podem conter informações sujeitas a regulamentos de proteção de dados, como o GDPR ou a HIPAA. A retenção inadequada ou o não cumprimento de requisitos legais podem levar a penalidades severas, enquanto a exclusão prematura pode prejudicar auditorias ou investigações [17], [18]. De forma a mitigar esses riscos, é essencial implementar medidas como criptografia de *logs* durante o armazenamento e transmissão, controlos rigorosos de acesso, padronização de formatos, monitorização contínua por meio de ferramentas como sistemas *Security Information and Event Management* (SIEM), uso de assinaturas digitais para garantir a integridade e adoção de políticas claras de retenção e eliminação segura [15], [16], [17].

Embora o *event logging* seja uma ferramenta indispensável, a sua gestão inadequada pode introduzir riscos significativos, destacando a importância de práticas robustas de segurança e conformidade.

2.4 *Event Logging* em Sistemas Operativos

O *event logging* tornou-se numa funcionalidade essencial dos sistemas operativos modernos, uma vez que pode ser utlizado para diversas aplicações e finalidades, desde

ajustes do sistema, a auditoria e funcionar também como um sistema de deteção de intrusão [7].

No caso de sistemas Unix/Linux, a implementação do *event logging* é realizada pelo *daemon Syslog* que é um programa que permite: a receção de mensagens locais *sylog,* tradicionalmente, por meio do *socket UNIX /dev/log* e de *logs* do *kernel*; a gravação de mensagens num arquivo (por norma, tudo é registado em arquivos como */var/log/messages* ou */var/log/syslog*, enquanto algumas categorias de mensagens são direcionadas para arquivos específicos, como */var/log/mail*); e o encaminhamento de mensagens para a rede ou outros destinos (normalmente, feito via UDP, no entanto, neste caso, o *daemon* também pode implementar escutadores de rede equivalentes) [19].

Por outro lado, no *Microsoft Windows*, utiliza-se o *Windows Event Log*. Este é um sistema altamente detalhado, que armazena informações sobre diversos eventos que ocorrem no sistema, como por exemplo, informações sobre: incidentes relacionados ao sistema operacional; erros que ocorrem nos *softwares* instalados no computador, eventos relacionados à configuração/instalação do sistema operacional, bem como registos de eventos de segurança (*logins* bem-sucedidos ou falhas de *login)* [20].

Para além disso, no *Windows Event Log* realiza-se ainda a categorização de eventos em cinco tipos principais [20]:

- Informação: Indica que uma aplicação ou serviço está a funcionar corretamente;
- Aviso: São eventos de baixa importância, que sinalizam potenciais problemas, como a falta de espaço no disco, por exemplo;
- Erro: Regista falhas e/ou problemas significativos que afetam o funcionamento do sistema (como, por exemplo, sistema operativo deixa de responder);
- Auditoria de sucesso: Regista uma tentativa válida de acesso de segurança auditado para o registo de segurança;
- Auditoria de falha: Indica uma falha de acesso de segurança auditado no registo de segurança, associada, portanto, a erros de autenticação.

Realiza-se ainda a classificação dos eventos do Windows consoante a sua severidade [20]:

- Informação: Eventos rotineiros sem impacto negativo. Informam que o evento ocorreu sem problemas;

- Verbose: Mensagens detalhadas para diagnósticos/eventos específicos;

- Aviso: Destaca um potencial problema que os administradores do sistema devem ter atenção;

- Erro: Descreve erros/problemas no sistema ou serviço que não requerem ação imediata;

- Crítico: Problemas graves que exigem resposta urgente.

Por fim, nos sistemas macOS, o *event login* é geridos principalmente por um sistema chamado Unified Logging System (ULS). O ULS substituiu o sistema de logs baseado no Syslog tradicional e centralizou o registo de eventos num formato mais eficiente e estruturado. Nestes, os logs do sistema encontram-se em */var/log/system.log* [21].

3. Análise de Riscos de Segurança

No presente capítulo, são analisados os riscos de segurança através do *event logging*.

3.1 Abordagens Utilizadas

A análise de riscos de segurança através de *event logging* segue uma abordagem estruturada, integrando tecnologias e práticas estabelecidas para identificar ativos críticos, ameaças potenciais e vulnerabilidades exploráveis. Sistemas como o *Syslog,* permitem a recolha e centralização de *logs*, agrupando dados de dispositivos diferentes, e fornecendo informações consistentes e padronizadas para monitorização. Assim, eventos críticos, como autenticações e alterações de configuração, podem ser rastreados, eliminando redundâncias e lacunas na recolha de dados [22].

Outro exemplo de tecnologia e ferramenta é o SIEM. O SIEM permite a monitorização em tempo real, notificações, correlação de eventos e análise acessível aos utilizadores, tratando-se de uma ferramenta de segurança que auxilia na identificação de potenciais falhas de segurança e ameaças antes que estas possam afetar as operações diárias [23].

A análise de *logs* desempenha um papel essencial na identificação de ameaças, que podem variar desde atacantes externos até utilizadores internos mal-intencionados. Ferramentas de análise de *logs*, como algoritmos *Python* ou técnicas de *K-Means Clustering*, são usadas para realizar *threat hunting*, identificando padrões incomuns que indicam tentativas de intrusão ou atividades suspeitas, como padrões de tentativas de *login* falhadas ou anomalias no comportamento do utilizador, relativamente a acessos em horários ou locais incomuns. Além disso, o uso de modelos específicos para diferentes tipos de ameaças fornece um mapa detalhado de vetores de ataque, possibilitando respostas mais rápidas e eficazes [24].

Para priorizar os riscos com base na probabilidade de ocorrência e no impacto potencial, algoritmos de *clustering* são aplicados a grandes volumes de dados de *logs*, facilitando a identificação rápida dos eventos mais críticos. Isso reduz a sobrecarga manual e destaca apenas os padrões significativos para análise e resposta [25]. Diversos tipos de abordagens para a deteção de anomalias em *log* realizam contagem das ocorrências de uma sequência específica ou de elementos dela ao longo de *traces* contidos no *log* de eventos, considerando essa contagem no processo de decidir se a sequência é anómala ou não [26].

A automação na análise de *logs* também permite a deteção de configurações fracas e práticas de armazenamento não seguras. Ferramentas automatizadas baseadas em *machine learning*, como *Splunk* (que utiliza análise de anomalias para identificar atividades suspeitas em tempo real e fornecer *insights* detalhados sobre falhas de configuração), *ELK Stack* (que suporta a identificação de problemas de configuração e armazenamento através da análise de *logs* agregados em uma infraestrutura distribuída) e modelos *LSTM-Based* (redes neurais recorrentes aplicadas para prever anomalias em sequências temporais de eventos nos *logs*) são opções eficazes para prever riscos e sugerir correções. Essas ferramentas otimizam a segurança dos sistemas de *logging*, minimizando a intervenção humana e erros associados. Além disso, permitem uma análise proativa e automática, tornando mais eficiente a mitigação de riscos de segurança relacionados aos *logs* e seus sistemas [27].

Para monitorizar e classificar o comportamento de sistemas baseado em *logs* em tempo real, estudos também propõem a utilização de um esquema de janela deslizante

em conjunto com um gráfico de controle estatístico, de forma a encontrar estruturas e classificar *logs* em relação a graus de anomalia [28]. Existem, também propostas de um classificador *ensemble* para identificar acessos maliciosos a partir das *logs* de acesso disponíveis em *datasets* públicos e classificadores utilizando *Isolation Forests* e *Deep Learning* para o mesmo *dataset* [29].

Após análise e identificação dos riscos, a resposta e mitigação tornam-se os passos finais, onde ferramentas como *Splunk* e *Graylog* desempenham um papel essencial neste processo. O *Splunk* oferece alertas automáticos, permitindo ações rápidas, como bloqueio de IPs maliciosos e notificações para equipas de TI [24]. Já o *Graylog* facilita a integração de incidentes, oferecendo fluxos de trabalho personalizáveis que garantem uma resposta eficiente. Ambas as ferramentas ajudam a automatizar a deteção e eliminação de riscos, melhorando a resposta a eventos críticos e a postura de segurança da organização [27].

3.2 Vulnerabilidades

Uma vulnerabilidade é uma fraqueza ou falha em *software* que pode permitir que atacantes obtenham algum nível de acesso não autorizado a uma máquina ou às informações armazenadas na mesma. A gravidade da vulnerabilidade está diretamente correlacionada com o nível de acesso não autorizado que um atacante pode obter ao explorá-la. As vulnerabilidades em *software* são geralmente encontradas no *firmware*, nos sistemas operativos ou nas aplicações que são executadas nos mesmos. Devido ao grande número de aplicações e sistemas operativos existentes, pode ser difícil determinar se o código em execução numa determinada máquina é vulnerável a ataques externos [30].

O *Event Log* é uma aplicação integrada ao *Internet Explorer*, presente em todas as versões do sistema operativo *Windows*, em virtude da estreita interdependência entre o navegador e o sistema. Devido ao conjunto específico de permissões atribuídas ao *Event Log*, duas vulnerabilidades de segurança significativas são suscetíveis de serem exploradas. A primeira, designada *LogCrusher*, permite que um utilizador do domínio cause o bloqueio remoto do *Event Log* em qualquer máquina *Windows* pertencente ao mesmo domínio. A segunda vulnerabilidade, identificada como *OverLog* possibilita ao

atacante (remoto) preencher o disco rígido de uma máquina Windows com dados de registos, resultando numa condição de negação de serviço (DoS). Ambas as falhas exploram o *Microsoft Event Log Remoting Protocol* (MS-EVEN), que expõe métodos de chamada de procedimento remoto (RPC) para acessos remotos, utilizando a função *OpenEventLog*, que permite ler, escrever e apagar registos de eventos em máquinas remotas [31].

Em suma, o papel desempenhado pelo *event logging* é deveras importante para a segurança dos sistemas, no entanto, as suas vulnerabilidades acarretam consequências graves, não só para as empresas como também para os utilizadores singulares. A possibilidade de ataques que exploram as falhas nos *logs* podem comprometer a integridade e a confidencialidade das informações, dificultar a identificação de incidentes e problemas e gerar prejuízos financeiros e morais. Estes riscos destacam a necessidade de ferramentas que mitigam as falhas e fortaleçam os sistemas. Reitera-se a importância das análises de impacto para antecipar e minimizar danos [32].

4. Práticas de Segurança Aplicáveis ao Event Logging

Finalmente, neste capítulo são abordadas as diretrizes essenciais para a configuração de registos de eventos, e estratégias para retenção de registos e monitorização de anomalias.

4.1 Diretrizes Essenciais para Configuração de Registos de Eventos

No registo de eventos, os *logs* contêm informações sobre a execução de um determinado sistema e são amplamente utilizados para diversas tarefas de gestão de sistemas. Como referido anteriormente, o registo de eventos é fundamental para uma ampla gama de finalidades relacionadas com a fiabilidade, incluindo a análise da causa raiz, caracterização de erros e falhas, deteção de anomalias, *debugging*, diagnóstico de desempenho e análise de alertas de segurança [33].

Contudo, vários estudos identificaram lacunas no que diz respeito ao *design* sistemático e às práticas de implementação do registo de eventos. Diferentes componentes de *software*, como sistemas operativos, *middleware* e aplicações,

frequentemente registam dados com formatos diferentes e sem qualquer coordenação entre si. Além disso, os problemas observados com *logs* industriais reais decorrem de informações limitadas e da ausência de diretrizes claras sobre como e o que registar. Neste contexto, práticas sistemáticas de registo desempenham um papel crucial, já que a colocação correta das instruções de registo pode aumentar a precisão dos *logs* em tempo de execução do sistema [33].

De forma a mitigar estas lacunas, é essencial adotar boas práticas no registo de eventos. Primeiramente, deve ser estabelecida uma política de registo, com base nos objetivos organizacionais e regulamentares. A segurança dos registos deve ser priorizada, assegurando que estes não exponham informações sensíveis e implementando controlos de acesso rigorosos para limitar quem pode visualizar e modificar os registos. Além disso, a estruturação adequada dos eventos é vital. Por exemplo, a utilização do *Network Time Protocol* garante *timestamps* coerentes nos eventos registados, enquanto o protocolo *Syslog* permite centralizar, transmitir e armazenar *logs* de vários dispositivos e sistemas num servidor centralizado. Outra prática recomendada é a monitorização e revisão dos registos. Agendar revisões periódicas dos registos para identificar padrões e configurar alertas automáticos para eventos críticos, como múltiplas tentativas de *login* falhadas, são medidas eficazes. Por fim, de forma a recolher, agregar e analisar registos automaticamente pode ser usado o SIEM, que permite otimizar a gestão e o tratamento de grandes volumes de *logs* [34].

4.2 Estratégias para Retenção de Registos

A implementação de políticas eficazes de retenção de *logs* é essencial para a segurança e conformidade organizacional. Assim, a manutenção de práticas robustas de retenção traz benefícios significativos, desde a simplificação da resposta a incidentes até ao cumprimento de requisitos legais e regulatórios. A retenção de *logs* facilita investigações de segurança ao preservar dados históricos detalhados, permitindo que as equipas analisem o percurso de um invasor e identifiquem sistemas comprometidos. Além disso, é uma exigência comum na obtenção de seguros cibernéticos, pois facilita avaliações pós-incidente conduzidas por especialistas, reduzindo custos e agilizando investigações [18].

No contexto de requisitos legais, muitas normas exigem períodos específicos de retenção de *logs*. De entre alguns exemplos, encontram-se a HIPAA (6 anos), PCI DSS (1 ano), ISO 27001 e NIST (3 anos), SOX (7 anos) e GLBA (6 anos). Assim, é essencial alinhar políticas de retenção com essas exigências para garantir conformidade [18].

Para além disto, a classificação de registos por sensibilidade é fundamental. *Logs* sensíveis, como financeiros ou médicos, devem ter retenção prolongada e segurança reforçada, enquanto registos menos críticos podem ter ciclos de vida mais curtos. O uso de camadas de armazenamento hierárquicas otimiza custos, mantendo *logs* recentes em sistemas de alto desempenho e, arquivando dados antigos em soluções mais económicas. Ferramentas automatizadas como *Splunk* ou *ELK Stack*, já explicados no capítulo 3.1., permitem configurar políticas de retenção, eliminando registos expirados e garantindo armazenamento seguro com criptografia. Assim, as políticas de retenção de *logs* tornam-se um elemento central na estratégia de segurança e conformidade organizacional [16], [35].

5. Conclusão

Em síntese, o processo de *event logging* consiste no registo e armazenamento de eventos, podendo ser parte integrante de um sistema operacional ou de uma aplicação específica. Como qualquer tecnologia, este possui tanto benefícios quanto limitações e vulnerabilidades, principalmente com o aumento contínuo de ciberataques que exploram as falhas de segurança associadas ao *event logging*. Deste modo, é importante o uso de ferramentas que possam mitigar as vulnerabilidades e riscos associados a este processo, bem como a adoção de políticas de retenção de *logs*, que irão fortalecer a segurança dos sistemas e proteger contra ameaças, e preservar a integridade operacional.

O desenvolvimento deste trabalho permitiu conhecer e concluir a existência de vulnerabilidades de segurança associadas ao *event logging*, bem como identificar quais práticas de segurança existem para lidar com os possíveis impactos negativos decorrentes dessas falhas, e usufruir das vantagens que a ferramenta que o *event logging* acarreta. Dada por concluída a elaboração deste trabalho, é possível inferir que o mesmo foi realizado com sucesso, tendo sido atingidos os objetivos inicialmente

propostos, com a aquisição e aprofundamento de conhecimentos associados às tecnologias da segurança computacional, principalmente relacionado ao *event logging*, tema e objeto deste relatório.

Referências

[1] P. Isabel, P. Santos, and H. Matos, “INSTITUTO SUPERIOR DE CIÊNCIAS POLICIAIS E SEGURANÇA INTERNA MESTRADO NÃO INTEGRADO EM CIÊNCIAS POLICIAIS NA ESPECIALIZAÇÃO EM SEGURANÇA INTERNA SEGURANÇA INFORMÁTICA: A Importância para a Segurança Interna Lisboa 2016.”

[2] V. Manuel Fernandes Lampreia *et al.*, “ACADEMIA DA FORÇA AÉREA A Segurança Computacional como fator de alinhamento entre Planos Organizacionais Dissertação para obtenção do Grau de Mestre em Aeronáutica Militar Especialidade de Piloto-Aviador Júri.”

[3] A. Saeckel, “Segurança informática vs. segurança da informação - qual é a diferença?,” Segurança da Informação versus Segurança de IT. Accessed: Dec. 07, 2024. [Online]. Available: https://www.dqsglobal.com/pt-pt/aprender/blog/seguranca-informatica-vs.-seguranca-da-informacao-qual-e-a-diferenca#it-sicherheit-vs-informationssicherheit-chapter01

[4] G. Mcgraw, “Building Security In,” 2004. [Online]. Available: www.computer.org/security/

[5] K. Padayachee, “An assessment of opportunity-reducing techniques in information security: An insider threat perspective,” *Decis Support Syst*, vol. 92, pp. 47–56, Dec. 2016, doi: 10.1016/j.dss.2016.09.012.

[6] G. González-Granadillo, S. González-Zarzosa, and R. Diaz, “Security information and event management (SIEM): Analysis, trends, and usage in critical infrastructures,” *Sensors*, vol. 21, no. 14, Jul. 2021, doi: 10.3390/s21144759.

[7] L. Zeng, Y. Xiao, H. Chen, B. Sun, and W. Han, “Computer operating system logging and security issues: a survey,” Nov. 25, 2016, *John Wiley and Sons Inc.* doi: 10.1002/sec.1677.

[8] A. Pecchia, M. Cinque, G. Carrozza, and D. Cotroneo, “Industry Practices and Event Logging: Assessment of a Critical Software Development Process,” in *Proceedings - International Conference on Software Engineering*, IEEE Computer Society, Aug. 2015, pp. 169–178. doi: 10.1109/ICSE.2015.145.

[9] I. Shah, L. Al Toaimy, and M. Jawed, “RWELS: A Remote Web Event Logging System,” 2008.

[10] M. Cinque, D. Cotroneo, and A. Pecchia, “Event logs for the analysis of software failures: A rule-based approach,” *IEEE Transactions on Software Engineering*, vol. 39, no. 6, pp. 806–821, 2013, doi: 10.1109/TSE.2012.67.

[11] B. Deokar and A. Hazarnis, “Intrusion Detection System using Log Files and Reinforcement Learning,” 2012.

[12] S. Kr, K. R. Suneetha, R. Krishnamoorthi, and S. Lecturer, “Identifying User Behavior by Analyzing Web Server Access Log File,” 2009. [Online]. Available: https://www.researchgate.net/publication/255583124

[13] "SOCKS5 Proxy Server Access Logs," blog: IP2World. Accessed: Dec. 07, 2024. [Online]. Available: https://www.google.com/search?q=IP2World&rlz=1C1ISCS_pt-PTPT945PT945&oq=IP2World&gs_lcrp=EgZjaHJvbWUyBggAEEUYOTIHCAEQABiABDIGCAIQABgeMgYIAxAAGB4yBggEEAAYHjIGCAUQABgeMgYIBhBFGDwyBggHEEUYPNIBBzExOGowajeoAgCwAgA&sourceid=chrome&ie=UTF-8

[14] A. Sainju and T. Atkison, "An experimental analysis of windows log events triggered by malware," in *Proceedings of the SouthEast Conference, ACMSE 2017*, Association for Computing Machinery, Inc, Apr. 2017, pp. 195–198. doi: 10.1145/3077286.3077295.

[15] A. Signals Directorate, "Best practices for event logging and threat detection," 2024.

[16] K. Kent and M. Souppaya, "Special Publication 800-92 Guide to Computer Security Log Management Recommendations of the National Institute of Standards and Technology."

[17] G. González-Granadillo, S. González-Zarzosa, and R. Diaz, "Security information and event management (SIEM): Analysis, trends, and usage in critical infrastructures," *Sensors*, vol. 21, no. 14, Jul. 2021, doi: 10.3390/s21144759.

[18] Blumira, "5 Best Practices For Security Log Retention." Accessed: Dec. 01, 2024. [Online]. Available: https://www.blumira.com/blog/5-best-practices-for-security-log-retention

[19] Radu Gheorghe, "What is Syslog: Daemons, Message Formats and Protocols," Sematext. Accessed: Dec. 07, 2024. [Online]. Available: https://sematext.com/blog/what-is-syslog-daemons-message-formats-and-protocols/

[20] "What is Windows Event Log? - IT Glossary," SolarWinds. [Online]. Available: https://www.solarwinds.com/resources/it-glossary/windows-event-log

[21] "A Guide to macOS System Logs," Trunc Help. [Online]. Available: https://help.trunc.org/knowledge-base/a-guide-to-macos-system-logs/

[22] A.D. Moskvichev and M.V. Dolgachev, "System of Collection and Analysis Event Log from Sources under Control of Windows Operating System," in *International Multi-Conference on Industrial Engineering and Modern Technologies*, IEEE, 2020, pp. 1–5.

[23] A. T. Ehis, "Optimization of Security Information and Event Management (SIEM) Infrastructures, and Events Correlation / Regression Analysis for Optimal Cyber Security Posture," *Archives of Advanced Engineering Science*, Jul. 2023, doi: 10.47852/bonviewAAES32021068.

[24] A. P. Jyothi, Chaithanya, A. Shankar, J. R. Ashwath Narayan, A. Anurag, and S. S. Kumar, "Threat Hunting in System Using Log Analysis," in *2024 International Conference on Knowledge Engineering and Communication Systems, ICKECS 2024*, Institute of Electrical and Electronics Engineers Inc., 2024. doi: 10.1109/ICKECS61492.2024.10616474.

[25] R. Vaarandi, M. Kont, and M. Pihelgas, "Event log analysis with the LogCluster tool," in *Military Communications Conference*, IEEE, 2016, pp. 982–987.

[26] "EPPC2020__Esther-EstherRojasKrugger".

[27] L. Korzeniowski and K. Goczyla, “Landscape of Automated Log Analysis: A Systematic Literature Review and Mapping Study,” 2022, *Institute of Electrical and Electronics Engineers Inc.* doi: 10.1109/ACCESS.2022.3152549.

[28] L. Decker and D. Leite, “Detecção de Anomalias em Logs para Manutenção Preditiva baseada em Sistema Fuzzy Evolutivo Fracamente Supervisionado,” Sociedade Brasileira de Automatica, Dec. 2020. doi: 10.48011/asba.v2i1.1539.

[29] P. Ceriotti Trindade, “UNIVERSIDADE FEDERAL DO RIO GRANDE DO SUL INSTITUTO DE INFORMÁTICA CURSO DE CIÊNCIA DA COMPUTAÇÃO.”

[30] B. Scholarsarchive and M. Somers Higbee, “Deriving System Vulnerabilities Using Log Analytics,” 2015. [Online]. Available: https://scholarsarchive.byu.edu/etd

[31] I. Arghire, “Endpoint SecurityWindows Event Log Vulnerabilities Could Be Exploited to Blind Security Products,” Remote attackers could exploit two Event Log vulnerabilities in Windows to crash the Event Log application and cause a denial-of-service (DoS) condition, Varonis warns. Accessed: Dec. 06, 2024. [Online]. Available: https://www.securityweek.com/windows-event-log-vulnerabilities-could-be-exploited-blind-security-products/

[32] A. Carolina and S. Dias, “Aplicação centralizada para a gestão e fusão de logs Mestrado em Cibersegurança e Informática Forense,” Jul. 2020.

[33] F. Baccanico, G. Carrozza, M. Cinque, D. Cotroneo, A. Pecchia, and A. Savignano, “Event logging in an industrial development process: Practices and reengineering challenges,” in *Proceedings - IEEE 25th International Symposium on Software Reliability Engineering Workshops, ISSREW 2014*, Institute of Electrical and Electronics Engineers Inc., Dec. 2014, pp. 10–13. doi: 10.1109/ISSREW.2014.69.

[34] K. Kent and M. Souppaya, “Guide to Computer Security Log Management Recommendations of the National Institute of Standards and Technology.” Accessed: Dec. 01, 2024. [Online]. Available: https://nvlpubs.nist.gov/nistpubs/legacy/sp/nistspecialpublication800-92.pdf.

[35] Oghenekome Urefe, Theodore Narku Odonkor, and Edith Ebele Agu, “Methodologies and best practices for audit and compliance in governmental financial management,” *Finance & Accounting Research Journal*, vol. 6, no. 8, pp. 1391–1402, Aug. 2024, doi: 10.51594/farj.v6i8.1383.